

GUÍA INFORMATIVA

Certificación ISO/IEC 27001:2022

Sistema de Gestión de Seguridad de la Información

Todo lo que su organización necesita saber
para certificarse con éxito

**Seguridad**

Riesgos
gestionados y
controles
verificados

**Reconocimiento**

Certificación con
validez internacional

**Confianza**

Ante clientes,
socios y
reguladores

Una guía práctica de **ONCE México** para entender
la norma, sus requisitos y el camino hacia la certificación.

¿Qué es ISO/IEC 27001:2022?

ISO/IEC 27001:2022 es la norma internacional líder para sistemas de gestión de seguridad de la información (SGSI). Establece los requisitos para establecer, implementar, mantener y mejorar continuamente un sistema que preserve la **confidencialidad, integridad y disponibilidad** de la información mediante la gestión de riesgos.

Aplica a organizaciones de cualquier tamaño y sector, públicas o privadas, y cubre la información en cualquier formato: digital, física o verbal. No es una norma exclusiva de las áreas de TI: es un sistema de gestión que integra procesos, personas y tecnología.

DATO CLAVE

El detonador más común para certificarse rara vez es la seguridad por sí misma: es **un cliente importante que la exige, una licitación que la pide como requisito o una obligación regulatoria o contractual**. La certificación convierte la seguridad en una ventaja comercial.

¿Qué busca ISO/IEC 27001?

Confidencialidad

Que la información sea accesible solo para quien está autorizado.

Integridad

Que la información sea exacta y completa, sin alteraciones indebidas.

Disponibilidad

Que la información esté accesible cuando la operación la necesita.

Gestión de riesgos

Identificar, evaluar y tratar los riesgos de seguridad según su contexto.

Los 7 elementos clave del SGSI

Un SGSI basado en ISO/IEC 27001 se sostiene sobre estos elementos, que la auditoría evalúa en conjunto:

- 1 Alcance bien definido**
Qué procesos, sitios y activos cubre el SGSI. Un alcance acotado es un factor clave de éxito.
- 2 Liderazgo de la dirección**
La alta dirección aprueba la política, asigna recursos y participa: no es un proyecto solo de TI.
- 3 Evaluación de riesgos**
Identificar activos, amenazas y vulnerabilidades. El análisis de riesgos es el eje de toda la norma.
- 4 Tratamiento y SoA**
Decidir cómo tratar cada riesgo y documentarlo en la Declaración de Aplicabilidad.
- 5 Controles implementados**
Controles del Anexo A seleccionados según los riesgos, operando y generando evidencia.
- 6 Personas competentes**
Personal capacitado y consciente de su papel en la seguridad de la información.
- 7 Mejora continua**
Medición, auditorías internas, revisión por la dirección y acciones correctivas.

Estructura y requisitos de ISO/IEC 27001:2022

La norma tiene dos partes: las **cláusulas 4 a 10**, con los requisitos obligatorios del sistema de gestión (no se pueden excluir), y el **Anexo A**, un catálogo de controles de seguridad que se seleccionan según los riesgos de cada organización.

CLÁUSULA 4

Contexto de la organización

Comprender la organización, su contexto, las necesidades de las partes interesadas y determinar el alcance del SGSI.

CLÁUSULA 5

Liderazgo

Compromiso de la alta dirección, política de seguridad de la información y asignación de roles y responsabilidades.

CLÁUSULA 6

Planificación

Evaluación y plan de tratamiento de riesgos, Declaración de Aplicabilidad (SoA) y objetivos de seguridad.

CLÁUSULA 7

Apoyo

Recursos, competencia del personal, toma de conciencia, comunicación e información documentada.

CLÁUSULA 8

Operación

Planificación y control operacional; ejecución periódica de la evaluación y el tratamiento de riesgos de seguridad.

CLÁUSULA 9

Evaluación del desempeño

Seguimiento, medición, análisis, evaluación, auditorías internas y revisión por la dirección.

CLÁUSULA 10

Mejora

No conformidades, acciones correctivas y mejora continua del SGSI. El sistema debe adaptarse a los cambios del contexto, de las amenazas y del negocio para mantenerse eficaz.

Anexo A — 93 controles en 4 temas

La versión 2022 organiza los controles de seguridad en cuatro grupos: **organizacionales (37)**, **de personas (8)**, **físicos (14)** y **tecnológicos (34)**. No es obligatorio implementarlos todos: se seleccionan según la evaluación de riesgos y cada inclusión o exclusión se justifica en la **Declaración de Aplicabilidad (SoA)**, el documento más distintivo de ISO/IEC 27001.

¿Qué información documentada se requiere?

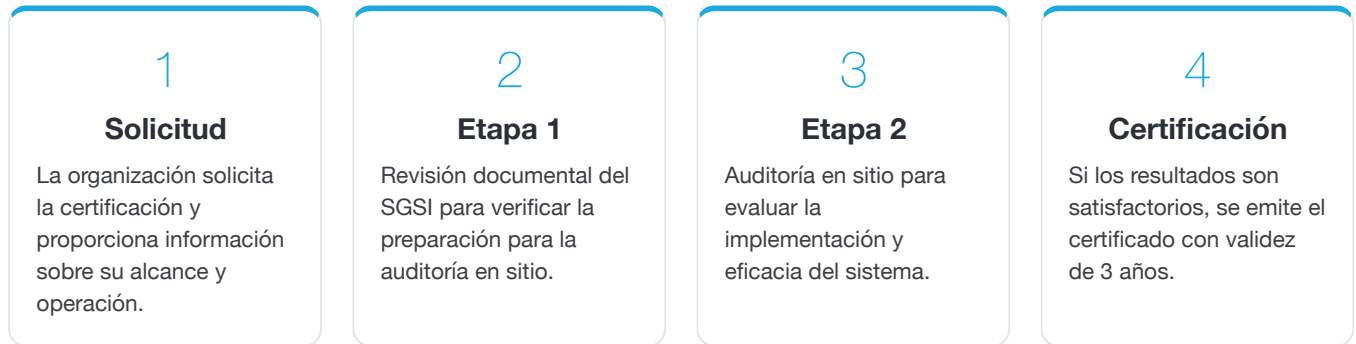
ISO/IEC 27001:2022 exige mantener y conservar información documentada en diversos puntos de la norma. A continuación los principales elementos que la auditoría verificará:

- **Alcance del SGSI**
Qué procesos, sitios y activos cubre el sistema (Cl. 4.3).
- **Proceso de evaluación de riesgos**
Metodología, criterios de aceptación y responsables (Cl. 6.1.2).
- **Objetivos de seguridad**
Metas medibles, con planes para lograrlas (Cl. 6.2).
- **Resultados de la evaluación de riesgos**
Riesgos identificados y su valoración periódica (Cl. 8.2).
- **Auditorías internas y revisión por la dirección**
Programa, resultados y decisiones tomadas (Cl. 9.2 y 9.3).
- **Política de seguridad de la información**
Compromiso documentado de la alta dirección (Cl. 5.2).
- **Declaración de Aplicabilidad (SoA)**
Controles aplicables, su justificación y las exclusiones (Cl. 6.1.3).
- **Competencia del personal**
Evidencia de formación, habilidades y experiencia (Cl. 7.2).
- **Plan de tratamiento de riesgos**
Acciones, controles y evidencia de su implementación (Cl. 8.3).
- **No conformidades y acciones correctivas**
Registro, análisis de causa raíz y acciones tomadas (Cl. 10.2).

Esta lista no es exhaustiva. La norma permite flexibilidad, pero el auditor puede solicitar **información documentada adicional** dependiendo del tamaño, complejidad y sector de la organización.

¿Cómo es el proceso de certificación?

El proceso de certificación con ONCE México sigue los lineamientos de **ISO/IEC 17021-1:2015** y se compone de las siguientes etapas:



Detalle de cada etapa



Cronograma típico

Fase 1 — Preparación (previo a la certificación)

Mes 1–6+ **Implementación del SGSI — 4 a 8 meses en promedio (según alcance y madurez)**

Fase 2 — Ciclo de certificación (una vez implementado el SGSI)



Beneficios de certificarse en ISO/IEC 27001

Confianza verificada

Un tercero independiente acredita que su seguridad opera como sistema.

Acceso a contratos

Clientes corporativos, financieros y licitaciones la exigen cada vez más.

Menos riesgo

Menor probabilidad e impacto de incidentes de seguridad de la información.

Cultura de seguridad

Personas, procesos y tecnología alineados bajo una disciplina de gestión.



Cumplimiento demostrable

Evidencia ante requisitos regulatorios, contractuales y de privacidad de datos.



Continuidad del negocio

El costo de un incidente supera ampliamente el costo de prevenirlo.



Decisiones basadas en riesgos

Inversión en seguridad dirigida a lo que realmente importa al negocio.



Ventaja competitiva

Diferenciación real frente a competidores que no cuentan con la certificación.

Preguntas frecuentes

¿Cuánto tiempo toma certificarse?

- El proceso de auditoría y certificación toma entre **2 y 4 meses** una vez que el SGSI está implementado. La implementación previa típicamente toma de **4 a 8 meses** con un alcance acotado, según la madurez de la organización.

¿Cuánto cuesta la certificación?

- La inversión depende del **tamaño de la organización** (número de empleados), la **complejidad de los procesos** y el **número de sitios** a auditar. ONCE México ofrece cotizaciones personalizadas sin compromiso.

¿Cuánto dura el certificado?

- El certificado tiene **validez de 3 años**, sujeto a auditorías de seguimiento anuales que verifican el mantenimiento y mejora del sistema.

¿Debo implementar los 93 controles del Anexo A?

- No. Los controles se **seleccionan según su evaluación de riesgos**; los que no apliquen pueden excluirse justificándolo en la Declaración de Aplicabilidad (SoA). La certificación no exige implementarlos todos.

¿Aplica para mi tipo de empresa?

- Sí. No necesita ser un banco ni una gran corporación: aplica a **cualquier organización que maneje información valiosa** — de clientes, empleados o propia — sin importar tamaño o sector. Tampoco es un proyecto exclusivo de TI.

¿Por qué certificarse con ONCE México?

ONCE México es un organismo de certificación comprometido con la excelencia y la accesibilidad. Nuestro enfoque combina rigor técnico con un trato cercano, guiando a cada organización durante todo el proceso de certificación.

Equipo calificado

Auditores con experiencia en múltiples sectores industriales y de servicios.

Proceso claro

Comunicación transparente en cada etapa, sin sorpresas ni costos ocultos.

Trato personalizado

Atención directa y adaptada al tamaño y necesidades de su organización.

Cobertura nacional

Capacidad para atender organizaciones en toda la República Mexicana.

Algunas normas que certificamos



ISO 9001:2015

Sistema de Gestión de la Calidad



ISO 14001:2015

Sistema de Gestión Ambiental



ISO 45001:2018

Seguridad y Salud en el Trabajo



ISO/IEC 27001:2022

Seguridad de la Información

Estos son solo algunos ejemplos. Consulte con nuestro equipo por otras normas y esquemas de certificación disponibles.

DATOS DE CONTACTO

ONCE México — Organismo de Normalización y Certificación Empresarial

Domicilio: Corporativo Kansas · Av. Insurgentes Sur 859, Piso 2, Col. Nápoles, Alcaldía Benito Juárez, C.P. 03810, Ciudad de México

Teléfono: 55 12 04 11 31

Correo: contacto@oncemexico.org

Web: www.oncemexico.org

Dé el primer paso hacia la certificación

Solicite una cotización personalizada sin compromiso. Nuestro equipo le guiará en cada etapa del proceso.

contacto@oncemexico.org

55 12 04 11 31